

# SIBER Güvenlik Tarama Raporu

Hedef: <https://fixture.test.example/>

Profil: Güvenli Tarama · Durum: Tamamlandı

Tarama ID: 5b8c81c4-5d8f-465a-8a86-ff9f4d83e733

Gözlem (tarama): 16.09.2026 11:33 UTC · Rapor oluşturma: 16.09.2026 11:33 UTC

## Yönetici özeti

Orta seviye iyileştirmeler önerilir. **Orta: 1 Bilgi: 1**

## Tarama kapsamı

|                                     |                                           |
|-------------------------------------|-------------------------------------------|
| Planlanan — profil                  | Güvenli Tarama                            |
| Yetki kaynağı                       | DNS doğrulaması                           |
| Planlanan motorlar                  | passive_http, sensitive_data, zap, nuclei |
| Gerçekleşen — tamamlanan motor      | 4                                         |
| Gerçekleşen — başarısız/zaman aşımı | 0                                         |
| Gerçekleşen — URL                   | ölçülmedi                                 |
| Gerçekleşen — bulgu                 | 2                                         |

## Motor çalışma özeti

| Motor        | Durum      | Kontrol türü | Bulgu | Süre  | URL       |
|--------------|------------|--------------|-------|-------|-----------|
| passive_http | Tamamlandı | HTTP/TLS     | 2     | 0.80s | ölçülmedi |
| nuclei       | Tamamlandı | Nuclei       | 0     | 2.10s | ölçülmedi |

## Bulgu özeti

| Önem  | Durum | Bulgular                              | Kural                          |
|-------|-------|---------------------------------------|--------------------------------|
| Orta  | Açık  | CSP: geniş kaynak izni                | generic.csp-wildcard-directive |
| Bilgi | Açık  | X-Powered-By başlığı bilgi sızdırıyor | x-powered-by-disclosure        |

## Bulgular (2)

**Orta** Durum: Açık

### CSP: geniş kaynak izni

Kaynak: zap · Kural: generic.csp-wildcard-directive

URL: https://fixture.test.example/

**Ne anlama geliyor?** CSP geniş kaynak izni içeriyor. Bu yapılandırma uyarısıdır; doğrulanmış XSS değildir. Gözlenen politika: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https:. Literal ``\*` yok; gözlenen geniş şema izinleridir.

#### Kanıt

Başlık adı: Content-Security-Policy  
Gözlenen değer: default-src 'self'; script-src 'self' 'unsafe-inline';  
style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https:  
Kanıt türü: HTTP yanıt başlığı  
URL: https://fixture.test.example/  
Kaynak: zap  
Kural: generic.csp-wildcard-directive

**Çözüm:** Gözlenen CSP kaynak izni geniş. Bu, doğrulanmış XSS sömürüsü değildir. Tek bir genel CSP'yi kesin çözüm diye uygulamayın; site bozulabilir.

1. Gözlenen politika: default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data: blob: https:
2. Kayıtlı metinde literal ``\*` yok; yıldız kullanılmış gibi yazılmamalı.
3. Geniş şema izni (ör. https: / data: / blob:) ile literal yıldız farklı şeylerdir.
4. Yalnız kanıtta görülen yönergeleri sıkılaştırın; hazır genel CSP kopyalaymayın.
5. Önce staging'de deneyin, sonra yeniden tarayın.

**Bilgi** Durum: Açık

### X-Powered-By başlığı bilgi sızdırıyor

Kaynak: passive\_http · Kural: x-powered-by-disclosure

URL: https://fixture.test.example/

**Ne anlama geliyor?** Saldırganlara hedef seçiminde ipucu verir.

#### Kanıt

Başlık adı: X-Powered-By  
Gözlenen değer: PHP/8.2.0  
Kanıt türü: HTTP yanıt başlığı  
URL: https://fixture.test.example/  
Kaynak: passive\_http  
Kural: x-powered-by-disclosure

**Çözüm:** X-Powered-By genelde uygulama veya barındırma katmanını gösterir; gözlenen değer Passenger/Plesk ise PHP veya IIS varsayılmaz.

1. Gözlemlenen değer: PHP/8.2.0
2. Başlığı hangi katmanın eklediği sunucu erişimi olmadan kesin bilinmeyebilir — proxy, uygulama ve panel ayarlarını kontrol edin.
3. PHP kaynaklıysa (değer PHP içeriyorsa): php.ini içinde expose\_php = Off.

4. Deęişiklik sonrası yeniden tarayıp başlıęı doęrulayın.